Eindrapport Risicoanalyse: Vanguard Healthcare

CASUS RISICOMANAGEMENT

Namen: Viresh Sheoratan, Muazma Anwar

Klas: CS101

Studentnmrs.: 500857506, 500900797

Docenten: Bas Schutte & Vijay Sewradj

Inhoudsopgave

1. Managementsamenvatting 4
2. Scope & context 4
3. Wet- en normenkader 4
4. Assetregister 5
5. Risicoregister + matrix 6
6. Scenario's 7
7. Top 5 risico's 8
8. Maatregelenplan + roadmap 9
9. Reflectie en verbeterpunten 12

1. Managementsamenvatting

Het doel van deze risicoanalyse is het in kaart brengen van de belangrijkste cyberkwetsbaarheden voor Vanguard Healthcare. De analyse maakt de risico's aantoonbaar zodat actie ondernomen kan worden ter verbetering van patiëntveiligheid, continuïteit van zorg en naleving van de AVG en NIS2.

Uit de analyse zijn 12 risico's geïdentificeerd, verdeeld over vier lagen: mensen,

bedrijfsprocessen, informatie/data/applicaties en infrastructuur. Twee risico's scoren Hoog

Twee risico's scoren Hoog (score 9):

- R1 – Phishing op medewerkers leidt tot ongeautoriseerde toegang tot EZPD en Vanguard Connect
- R11 – Onveilige netwerkconfiguraties (Telnet, SNMP public, plain-text wachtwoorden) maken volledige netwerkovername mogelijk

De overige tien risico's scoren Midden (score 6). Hoewel lager gescoord, hebben ook deze risico's directe impact op patiëntveiligheid. Met name R8 (ransomware op back-ups en eindpoints), R10 (ontbrekende netwerksegmentatie) en R9 (kwetsbare medische IoTapparatuur) vereisen prioritaire aandacht.

2. Scope & context

De risicoanalyse richt zich op de digitale omgeving van Vanguard Healthcare en is uitgevoerd op basis van de aangeleverde casusdocumentatie. Er zijn geen interviews uitgevoerd met processeigenaren, IT of management, en er zijn geen technische scans verricht. BIV-waarden zijn inschattingen; de exacte impact kan afwijken.

De analyse is uitgevoerd volgens het 4-lagenmodel, BIV-classificatie, ISO 27005 risicobeoordeling en het NIST Cybersecurity Framework.

Buiten scope vallen onder andere: de implementatie van verbetermaatregelen, pentests, patiëntdevices en medische apparatuur die niet aan een netwerk is gekoppeld.

3. Wet- en normenkader

Vanguard Healthcare valt als zorginstelling onder de AVG vanwege de verwerking van bijzondere persoonsgegevens, en onder de NIS2-richtlijn als essentiële zorginstelling. Daarnaast hanteert de organisatie ISO 27001, ISO 27005 en NEN 7510 als normenkader voor informatiebeveiliging en risicobeheer.

Onderstaande tabel koppelt per wet de relevante assets aan de bijbehorende artikelen, eisen en normen. Dit maakt zichtbaar waar Vanguard Healthcare op dit moment risico loopt op niet-naleving.

Wet	Asset	Artikel	Eis	ISO/NEN
AVG	EZPD, Vanguard Connect	Art. 5(1)f, 32	Passende beveiliging bijzondere persoonsgegevens	ISO 27001 A.8.5; NEN 7510 11.5
AVG	DLO, Gebruikersaccounts	Art. 9, 33, 34	Meldplicht datalek; bescherming bijzondere categorieën	ISO 27001 A.5.18; NEN 7510 11.1
AVG	Externe verwerkers (cloud, lab)	Art. 28	Verwerkersovereenkomst; contractuele beveiligingseisen	ISO 27005 §8; NEN 7510 14.2
NIS2	Netwerk, EZPD, IoT	Art. 21 lid 2	Risicobeheer, segmentatie, MFA, patch management	ISO 27001 A.8.22; NEN 7510 13.1
NIS2	Cloudleverancier, ICT-keten	Art. 21 lid 2d	Leveranciersbeveiliging; SLA/BCP aantoonbaar	ISO 27001 A.5.19; ISO 27005 §8
NIS2	Alle systemen	Art. 23	Meldplicht significante incidenten binnen 24u	ISO 27001 A.5.24; NEN 7510 16.1

Het niet naleven van deze eisen kan leiden tot reputatieschade, financiële sancties en verlies van vertrouwen bij patiënten en partners.

4. Assetregister

Binnen Vanguard Healthcare zijn assets geïdentificeerd verdeeld over vier organisatielagen. De onderstaande tabel toont per laag de twee assets. De BIV-score geeft aan hoe kritiek een asset is op het gebied van beschikbaarheid, integriteit en vertrouwelijkheid.

Asset	Laag	B	I	V	Toelichting
Zorgmedewerkers	Mensen	H	H	H	1.100 medewerkers; dagelijks afhankelijk van digitale systemen voor zorgverlening

Gebruikersaccounts	Mensen	M	H	H	Accounts niet altijd tijdig aangepast bij functiewijzigingen of uitdiensttreding
Zorgverlening	Bedrijfsprocessen	H	H	H	Kernproces; digitale uitval leidt direct tot vertraging of stilstand van zorg
HR & Planning	Bedrijfsprocessen	M	H	H	Cloud-gebaseerd; gekoppeld aan identity management; privilege creep risico
EZPD	App/Data	H	H	H	Primair zorgsysteem; uitval = directe patiëntimpact op alle 7 locaties
Vanguard Connect	App/Data	H	H	H	Patiëntportaal; direct internet-exposed; REST/FHIR API-koppelingen
Netwerkinfrastructuur	Infrastructuur	H	H	M	KPN glasvezel WAN; 7 locaties; FortiGate NGFW; onveilige switch/router config (R11)
Systeem Back-ups	Infrastructuur	H	H	H	Deels leverancier-beheerd; restore nooit getest; geen gedocumenteerde RTO/RPO

5. Risicoregister + matrix

Voor elk van de 12 geïdentificeerde risico's is de kans en impact bepaald op basis van de kwetsbaarheden uit de casus. De scoring is gebaseerd op een combinatie van kans en impact (L/M/H), resulterend in een numerieke score en risiconiveau. De kwetsbaarheden zijn onder andere: MFA niet organisatiebreed afgedwongen, accounts niet tijdig gedeprovisioneerd, autorisaties afhankelijk van correcte handmatige invoer, en verouderde software op medische IoT-apparatuur

Risicoregister

ID	Laag	Asset	Dreiging	Kans	Impact	Score	Niveau
R1	Mensen	EZPD, Vanguard Connect, Gebruikersaccounts	Phishing / credential theft	H	H	9	Hoog
R2	Infrastructuur	Cloud hosting, Identity Management	Account takeover / brute-force	M	H	6	Midden

R3	Bedrijfsproces	DLO	Ongewenste inzage exstagiairs	M	H	6	Midden
R4	Bedrijfsproces	DLO + reflectieverslagen	Privacy-incident herleidbare patiëntinfo	M	H	6	Midden
R5	Bedrijfsproces	HR & Planning + Identity management	Privilege creep na functiewijziging	M	H	6	Midden
R6	Infrastructuur	VPN externe zorgprofessionals	Misbruik VPNaccount	M	H	6	Midden
R7	App/Data	Cloudomgeving (EZPD hosting)	Onbeschikbaarheid cloudleverancier	M	H	6	Midden
R8	App/Data	Back-ups + Eindpoints	Ransomware, herstel faalt	M	H	6	Midden
R9	Infrastructuur	Medische IoTapparatuur	Exploit kwetsbare IoT	M	H	6	Midden
R10	Infrastructuur	Netwerksegmentatie	Laterale beweging naar EZPD/IoT	M	H	6	Midden
R11	Infrastructuur	Routers/Switches	Aanval via onveilige beheerpoorten	H	H	9	Hoog
R12	Infrastructuur	PLC verlichting SEH/ICU	Cyberaanval op PLC/HMI	M	H	6	Midden

Risicomatrix

Kans \ Impact	Laag	Midden	Hoog
Hoog			**R1, R11**
Midden			R2–R10, R12
Laag			

6. Scenario’s

Om de risico's concreet te maken zijn acht aanvalsscenario's uitgewerkt. De scenario's zijn gebaseerd op de kwetsbaarheden en dreigingen uit het risicoregister. Een eerder phishing-incident waarbij een medewerker inloggegevens invoerde op een neppagina, en een cloudstoring die leidde tot twee uur EZPD-downtime, tonen aan dat meerdere scenario's al gedeeltelijk zijn opgetreden bij Vanguard Healthcare.

Nr	Risico	Scenario	Aanvalspad (samenvatting)	Impact
S1	R1	Phishing op zorgmedewerker	Verpleegkundige klikt link → EZPD-credentials gestolen → aanvaller raadpleegt/wijzigt dossiers → datalek	Hoog
S2	R11	Netwerkovername via Telnet/SNMP	Aanvaller scant intern netwerk → logt in via Telnet (plain-text wachtwoord) → VLAN-hopping → EZPD bereikbaar	Hoog
S3	R8	Ransomware uitrol via macro	Macro-document → RAT installatie → laterale beweging → EZPD + back-ups versleuteld → dagenlange uitval	Hoog
S4	R5	Privilege creep na overplaatsing	IC-medewerker naar admin → oude rechten blijven → raadpleegt dossier bekende patiënt → datalek	Midden
S5	R12	Cyberaanval op PLC/SEH verlichting	Via eerder gecompromitteerd netwerk → PLC zonder authenticatie → lichtfluctuaties tijdens operatie	Midden
S6	R7	Cloudleverancier downtime	Netwerkmigrate mislukt → EZPD 4,5u onbereikbaar → papieren noodprocedures → medicatiefouten risico	Midden
S7	R3	Oud-stagiair toegang DLO	Stage beëindigd maar account actief → inzage reflectieverslagen met patiëntdata → verspreiding	Midden
S8	R9	IoT-exploit medische apparatuur	Kwetsbare firmware infuuspomp → manipulatie dosering → direct patiëntrisico	Hoog

7. Top 5 risico’s

De vijf risico's met de hoogste score zijn geselecteerd op basis van het risicoregister. R1 en R11 scoren Hoog (9). R8, R9 en R10 scoren Midden (6) maar zijn opgenomen vanwege de directe impact op patiëntveiligheid en de onderlinge samenhang: een gecompromitteerde

router (R11) maakt laterale beweging (R10) mogelijk, waarmee zowel medische IoT (R9) als back-ups (R8) bereikbaar worden.

ID	Score	Omschrijving	Patiëntimpact	Compliance
R1	9	EZPD, Vanguard Connect, Gebruikersaccounts – Phishing / credential theft	Manipulatie dossiers, medicatiefout	AVG Art.32/33; NIS2 Art.21
R11	9	Routers/Switches – Aanval via Telnet, SNMP public, plain-text wachtwoorden	Netwerk plat, alle zorg stilvalt	NIS2 Art.21; AVG meldplicht
R8	6	Back-ups + Eindpoints – Ransomware, herstel faalt door niet-geteste back-ups	EZPD dagen onbeschikbaar	AVG Art.32; NIS2 Art.21 BCM
R10	6	Netwerksegmentatie – Laterale beweging werkplek → medische apparatuur/EZPD	Infuuspompen bereikbaar voor aanvaller	NIS2 Art.21; NEN 7510 13.1
R9	6	Medische IoT – Exploit kwetsbare apparatuur leidt tot verstoring/datamanipulatie	Verkeerde meetwaarden → foute diagnose	NIS2 Art.21; NEN 7510 12.6

8. Maatregelenplan + roadmap

Maatregelenplan

Voor de vijf hoogst scorende risico's zijn maatregelen geformuleerd op drie niveaus: preventief, detectief en correctief. De maatregelen zijn gekoppeld aan een verantwoordelijke rol en onderbouwd met MITRE ATT&CK-technieken, ISO 27001, ISO 27005 en NEN 7510.

RisicoID	Type maatregel	Maatregel	Rol (owner)	Evidence (bewijs)
R1	Preventief	Organisatiebrede uitrol van MFA voor alle gebruikersaccounts (EZPD, Vanguard Connect, DLO, VPN), inclusief zorgmedewerkers en externe professionals	IT Security Manager	MFA-configuratierapport; screenshot Azure AD MFA-status per gebruiker; auditlog succesvolle MFA-inlog

R1	Detectief	SIEM-alerting op verdachte inlogpogingen: inloggen buiten werktijden, onbekende locaties, meerdere mislukte pogingen	SOC Analist / ITbeheer	SIEM-dashboard met alertregels; incidentlogboek; maandelijkse rapportage anomalous logins
R1	Correctief	Incident response procedure voor accountcompromittering: direct vergrendelen account, wachtwoordreset, forensisch onderzoek en AVG-meldplicht	CISO / Privacy Officer	Incident response playbook; aantoonbare meldingen bij AP; post-incident rapport
R11	Preventief	Netwerksegmentatie: scheiding van beheernetwerk (OOB management) van productie- en IoT-netwerken via VLAN's en firewallregels	Netwerkbeheerder / IT Manager	Firewall-ruleset documentatie; VLAN-configuratie export; netwerktopologiediagram
R11	Detectief	Intrusion Detection System (IDS/IPS) op kritieke netwerksegmenten; logging van alle beheerverkeer via syslog/SIEM	SOC Analist / Netwerkbeheerder	IDS-alertrapportage; syslogconfiguratiebewijs; maandelijks netwerkauditrapport
R11	Correctief	Isolatieprocedure voor gecompromitteerde netwerksegmenten: automatisch of handmatig isoleren van aangetast segment, rollback naar veilige configuratie	Netwerkbeheerder / CISO	Gedocumenteerde isolatieprocedure; hersteltestrapportage; change management log
R2	Preventief	Afdwingen sterk wachtwoordbeleid (min. 14 tekens, complexiteit) en account lockout-policy na 5 mislukte pogingen voor alle accounts	IT Security Manager / Identity Beheer	Active Directory/Azure AD wachtwoordbeleid export; configuratiedocument account lockout
R2	Detectief	Monitoring op brute-force patronen via Azure AD Identity Protection: alerts bij >5 mislukte inlogpogingen binnen 10 minuten	SOC Analist / ITbeheer	Azure AD Identity Protection rapport; SIEM-alertconfiguratie screenshot; maandelijkse alertreview log

R2	Correctief	Automatische tijdelijke blokkade van getroffen accounts en notificatie aan ITbeheer; herstel via gecontroleerde heractivatieprocedure	IT Security Manager / Helpdesk	Helpdesk tickets bij accountblokkade; herstelrapportage; bewijs van gecontroleerde heractivatie
R3	Preventief	Geautomatiseerd offboardingproces: koppeling stagecontract-einddatum aan automatische deactivering DLO-account op dag van vertrek	HR Manager / Stagebegeleider / IT-beheer	Configuratiedocument automatische deactivering; HR-IT koppeling testrapport; audit inactieve accounts
R3	Detectief	Maandelijkse access review: geautomatiseerde rapportage van accounts actief na einddatum stagecontract of zonder recente loginactiviteit	IT-beheer / Stagebegeleider	Maandelijks account review rapport; aantoonbaar verwijderde verlopen accounts; reviewlog
R3	Correctief	Direct deactiveren geïdentificeerde verlopen accounts en audit van raadplegingen; bij datalek: AVG-meldprocedure activeren	Privacy Officer / ITbeheer	Overzicht verwijderde accounts per kwartaal; audit-log raadplegingen; incident rapport indien datalek
R8	Preventief	3-2-1 back-upstrategie: dagelijkse back-ups op 3 locaties (lokaal, cloud, offline), inclusief immutable back-ups voor EZPD-data	IT Manager / Cloudleverancier	Back-upconfiguratie documentatie; bewijs offline/immutable kopie; testrapport herstel laatste 3 maanden
R8	Detectief	EDR op alle werkstations en servers: real-time detectie van ransomware-gedrag (massale bestandsencryptie, shadow copy deletion)	SOC Analist / IT Security	EDR-licenties en deploymentstatus; alert-log EDR afgelopen kwartaal; bewijs shadow copy monitoring
R8	Correctief	Getest Disaster Recovery Plan (DRP) met RTO ≤4 uur voor EZPD en RPO ≤24 uur; jaarlijkse hersteltest verplicht	IT Manager / CISO	DRP-document met gedocumenteerde RTO/RPO; hersteltest rapport; aantoonbaar goedgekeurd door directie

R8	Preventief	Endpoint hardening: uitrol EDR op alle werkstations en blokkeer macro-uitvoering in Office-documenten om initiële ransomware-infectie via phishing/macro te voorkomen	IT Security Manager	EDR-deployment rapport; bewijs macro-blokkade in GPO; maandelijkse alert-rapportage endpoints

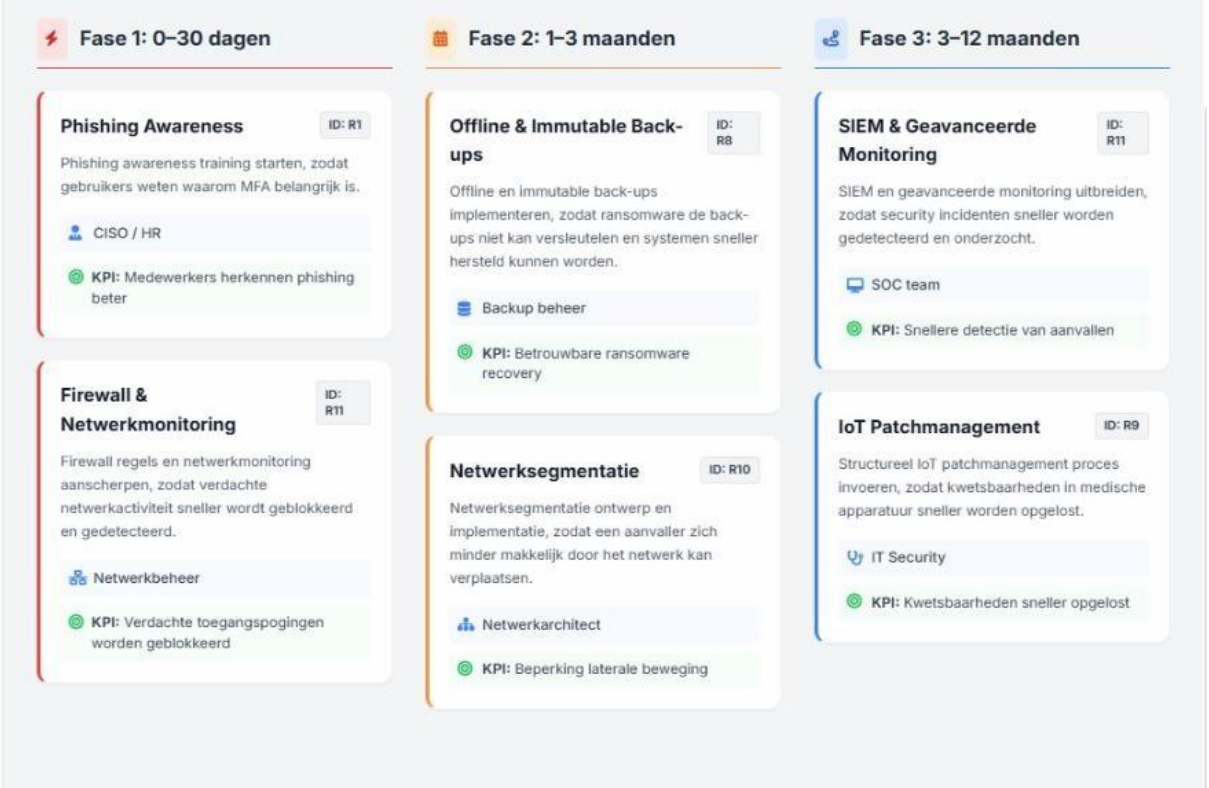
Roadmap

De uitvoering is ingedeeld in drie fasen.

Fase 1 (0–30 dagen) richt zich op quick wins: phishing awareness training (R1) en aanscherpen van firewallregels en netwerkmonitoring (R11).

Fase 2 (1–3 maanden) omvat offline/immutable back-ups (R8) en netwerksegmentatie (R10).

Fase 3 (3–12 maanden) betreft structurele verbeteringen: uitbreiding van SIEMmonitoring (R11) en invoering van een IoT-patchmanagementproces (R9)



9. Reflectie en verbeterpunten

In dit project hebben wij niet met vaste rollen gewerkt. Alle taken zijn gezamenlijk opgepakt, waarbij we samen de risicoanalyse hebben uitgevoerd en elkaar aanvulden waar nodig.

Het lastigste onderdeel was het koppelen van risico's aan de bijbehorende wet- en regelgeving. Vooral het opzoeken van de juiste wetsartikelen was in het begin tijdrovend.

Het meest opvallende was het ontbreken van netwerksegmentatie. Medische apparaten staan op hetzelfde netwerk als gewone werkplekken, waardoor een aanvaller die via één apparaat binnenkomt mogelijk toegang krijgt tot kritieke medische systemen. Dit had relatief eenvoudig beperkt kunnen worden door het netwerk beter in te delen.

In de casus ontbrak informatie die nodig was om risico's betrouwbaar te beoordelen, zoals de MFA-status per systeem, hoe snel accounts worden verwijderd bij uitdiensttreding, of monitoring 24/7 actief is en of er recent restoretests zijn uitgevoerd. Om deze informatie te verzamelen hebben wij een verzoek ingediend bij de Raad van Bestuur van Vanguard Healthcare.

De maatregel met de grootste impact is netwerksegmentatie. Zelfs als een aanvaller het netwerk binnendringt, zorgt goede segmentatie ervoor dat hij zich niet vrij kan bewegen tussen medische apparatuur, het EZPD en werkplekken. Dit beperkt de schade bij een aanval aanzienlijk. In de praktijk zou een groter cybersecurityteam met focus op monitoring en preventie, in plaats van alleen operationeel beheer, de veiligheid van Vanguard Healthcare structureel kunnen verbeteren.